

7 Laboratorinis darbas. Skaitmeninis parašas

Asimetrinės šifravimo kriptosistemos

Asimetrinės šifravimo kriptosistemos turi du raktus: viešąjį ir privatųjį. Viešasis raktas yra skelbiamas viešai, privatusis – saugomas paslapyje. Abu raktai gali būti naudojami pranešimo šifravimui.

- Kai pranešimas šifruojamas viešuoju raktu, jį atšifruoti galima tik privačiuoju raktu. Tai užtikrina, kad pranešimą galės perskaityti tik privataus rakto savininkas.
- Kai pranešimas šifruojamas privačiuoju raktu, jį atšifruoti galima tik viešuoju raktu. Tai užtikrina, kad pranešimą siuntė viešojo rakto savininkas. Tai ir yra skaitmeninis parašas.

Viešojo rakto identifikavimas

Parašui patvirtinti pakanka turėti viešąjį raktą. Tačiau, kaip patikrinti kokiam asmeniui ar serveriui priklauso viešasis raktas? Viešojo rakto identifikavimui naudojami sertifikatai. Sertifikatai leidžia susieti viešąjį raktą su reikalinga informacija (pvz. domenu).

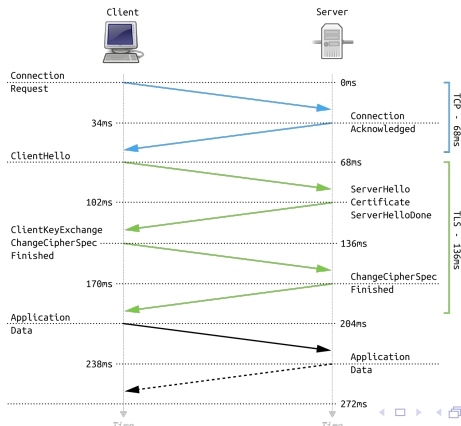
Sertifikatų tipai

- TLS
- El. pašto
- EMV (Europay, Mastercard, Visa)
- Kodo pasirašymo
- Kvalifikuoti el. parašo
- ir kt.

TLS (angl. *Transport Layer Security*)

TLS

HTTP protokolu, tinklu siunčiami duomenys gali būti lengvai perskaityti. Duomenų konfidencialumą užtikrina HTTPS (HTTP per TLS) protokolas. Konfidencialus bendravimas tinklu yra užtikrinamas TLS rankos paspaudimu (angl. *TLS handshake*), kurio metu serveris pateikia savo sertifikatą klientui.



TLS sertifikato struktūra

- Serijinis numeris
- Galiojimo pradžia ir pabaiga
- Informacija apie sertifikato turėtoją (domenas, įmonės pavadinimas, šalis, miestas)
- Sertifikato savininko viešasis raktas
- Informacija apie sertifikatą išdavusį vienetą (domenas, įmonės pavadinimas, šalis, miestas)
- Nuoroda į sertifikatą pasirašiusį sertifikatą
- Pasirašymo algoritmas
- Sertifikatą išdavusio vieneto parašas
- ir kt.

Sertifikavimo tarnybos

Sertifikatų autentiškumas yra paremtas pasitikėjimu. Sertifikatą išduoti ir pasirašyti gali bet kas, tačiau, jie bus laikomi patikimais tik tada, jei programinė įranga, kuri bendrauja su serveriu (pvz. naršyklė arba operacinė sistema), manys, kad sertifikatas yra patikimas.

Patikimus sertifikatus gali išduoti tik sertifikavimo tarnybos (CA), kuriomis programinė įranga pasitiki.

Norint tapti patikima CA reikia atitikti labai griežtus reikalavimus. Šiuos reikalavimus kelia, ne įstatymai, bet pačios įmonės (pvz. Apple, Microsoft ar Firefox). Ne visos įmonės gali sau leisti taikyti tokius reikalavimus, todėl programinė įranga dažnai naudoja operacinės sistemos arba Firefox patikimų CA sąrašus.

Sertifikatų autentifikavimas

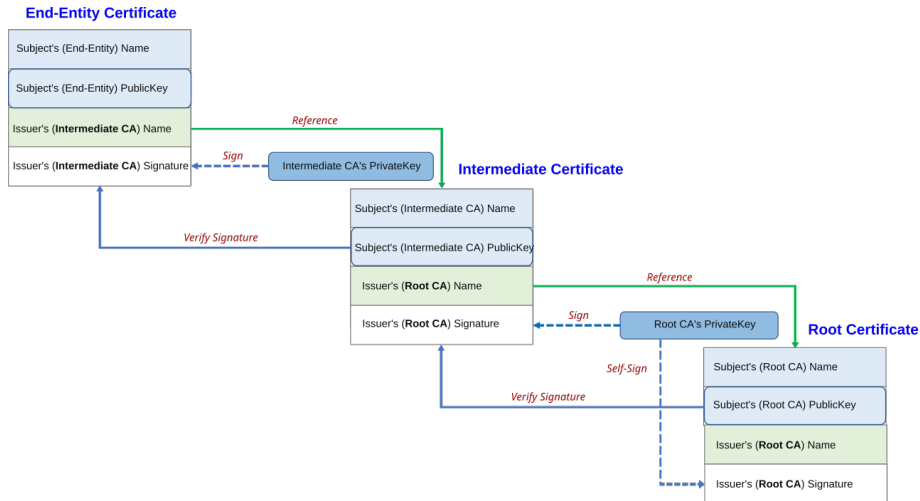
- Vartotojui (naršyklei) užmezgus ryšį su serveriu, vartotojui yra perduodama sertifikatų grandinė. Grandinė prasideda serverio sertifikatu ir baigiasi CA sertifikatu.
- Naršyklė patikrina ar sertifikatas yra galiojantis (ar galiojimo laikas nepasibaigęs ir ar domenas sutampa su sertifikate įrašytu domenu) ir ar tikrai pasirašytas aukštesnės grandies sertifikato.
- Jei grandinė sėkmingai pasiekiamas patikimas CA sertifikatas, serverio sertifikatas laikomas saugiu.

Sertifikatų atėmimas

Jei sertifikatų savininkai nesilaiko CA reikalavimų arba jei sertifikato savininko privatusis raktas buvo nutekintas, sertifikatų galiojimas gali būti nutrauktas. Sertifikatų atėmimą dažniausiai inicijuoja patys savininkai, kai sužino apie privataus rakto nutekinimą.

Patikrinti, ar sertifikato galiojimas nutrauktas galima susisiekus su CA.

Sertifikato pasitikėjimo grandinė



Domeno validacijos (angl. *Domain validation* arba DV)

Užtikrina, kad sertifikato savininko domenas ir viešasis raktas yra toks, koks nurodytas sertifikate. Sertifikatų išdavimas būna automatizuotas. Dažniausiai sutinkami tokio tipo sertifikatai, nes jie yra pigiausi.

Organizacijos validacijos (angl. *Organization validation* arba OV)

Užtikrina, kad sertifikato savininko domenas, viešasis raktas ir įmonė yra tokie, kokie nurodyti sertifikate. Sertifikatų išdavimas atliekamas rankiniu būdu. Patikrinamas įmonės egzistavimas.

Išplėtosios validacijos (angl. *Extended validation* arba EV)

Užtikrina, kad sertifikato savininko domenas, viešasis raktas ir įmonė yra tokie, kokie nurodyti sertifikate. Įmonės autentifikavimo patikra yra griežtesnė. Naudojami retai, nes yra brangūs ir neleidžia naudoti *wildcard* domenų.

RSA parašas

Pasirašyti pranešimui naudojamas RSA privatusis raktas. Parašas siunčiamas kartu su pranešimu.

$$s = m^d \mod n$$

čia s - parašas, m - pranešimas, (d, n) - privatus raktas.

Parašo verifikavimas

Parašui verifikuoti apskaičiuojama reikšmė $m_2 = s^e \mod n$. Jei $m = m_2$ - pranešimas buvo pasirašytas privataus rakto, jei $m \neq m_2$ pranešimas buvo modifikuotas arba parašas yra suklustotas.

Parašas

Failai (pvz. sertifikatai) dažnai būna didesni nei n . Todėl, pasirašant failą šifruojamas ne pats failas, o failo piršto antspaudas (angl. *fingerprint*) - failas sumaišytas maišos funkcija.

$$s = h(m)^d \mod n$$

čia s - parašas, h - maišos funkcija, m - failas, (d, n) - privatus raktas.

Parašo verifikavimas

Parašui verifikuoti apskaičiuojamos dvi reikšmės $hash_1 = h(m)$ ir $hash_2 = s^e \mod n$. Jei $hash_1 = hash_2$ - failas buvo pasirašytas privataus rakto, jei $hash_1 \neq hash_2$ failas buvo modifikuotas arba parašas yra suklastotas.

Tarkime turime failą m , kuris bus sumaišytas maišos funkcija $SHA256$

$SHA256(m) = 51166318ed5da66eb31be6665f2256e1b4bf0f3253f6216dd39743920dfc9b29_{16}$

$SHA256$ grąžina šešioliktainį skaičių (baitus), o **ne string**. Todėl, konvertuojant šią reikšmę į dešimtainę sistemą turėtų būti gaunama:

$SHA256(m) = 36676895315594292743914449324165339493834453249929853708975242439162368662313_{10}$

Jei ta pati reikšmė bus laikoma UTF-8 *string* tipo parametru bus gaunama

$SHA256(m) =$
27858993226817794536407161906510323356358927569525711830239968300190695608359105184960041881951129
11504136084950688180297859162252578536855347650688594489₁₀

Kai kurios CA siūlo ir failo pasirašymo su laiko žyma paslaugas, tuomet CA yra vadinama TSA (angl. *Timestamping Authority*). Toks parašas yra skirtas nurodyti vėliausią failo sukūrimo datą.

Pasirašymas

- Vartotojas nusiunčia failo m piršto antspaudą TSA

$$hash_1 = h(m)$$

- TSA prie $hash_1$ prideda dabartinį Unix laiką ts sekundėmis baitais ir apskaičiuoja gautos reikšmės $hash_2$

$$hash_2 = h(hash_1 || ts_{16})$$

- TSA pasirašo $hash_2$ savo privačiuoju raktu

$$s = hash_2^d \mod n$$

- TSA grąžina vartotojui s ir ts
- Vartotojas kartu saugo m , s ir ts

Parašo verifikavimas

Apskaičiuojamos dvi reikšmės $hash_1 = h(h(m)||ts_{16})$ ir $hash_2 = s^e \bmod n$.
Jei $hash_1 = hash_2$ - failas buvo pasirašytas privataus rakto laiko momentu ts , jei $hash_1 \neq hash_2$ failas buvo modifikuotas arba parašas yra suklastotas.

Maišos funkcijų ir laiko žymos konvertavimas

Tarkime turime failą m , kuris bus sumaišytas maišos funkcija $SHA256$ ir pasirašytas Unix laiku $ts = 1729525901_{10}$.

$$hash_1 = SHA256(m) = 51166318ed5da66eb31be6665f2256e1b4bf0f3253f6216dd39743920dfc9b29_{16},$$

Laiko žyma konvertuojama į šešioliktainę sistemą (baitus):

$$ts_{16} = 1729525901_{10} = 6716788d_{16},$$

Reikšmės apjungiamos:

$$hash_1||ts_{16} = 51166318ed5da66eb31be6665f2256e1b4bf0f3253f6216dd39743920dfc9b296716788d$$